AI Setup

(Using Ollama)

Setup each session on a lab computer…

- Clone repository
- Run setup PowerShell script (from repo)
- Install/check Ollama
- Download the specified model with Ollama pull
- Create my own customised model
- Launch it

I checked a computer in the AI labs for the hardware it has and its default software

The AI Labs have the following…
System RAM: 64 GB DDR5

Dedicated GPU: NVIDIA GeForce RTX 5080 with about 16 GB VRAM

Integrated GPU: Intel graphics with up to 48 GB **shared** memory

Storage: 565 GB free

Git: installed

Ollama: not installed by default

I looked into hosting an LLM using Ollama - the best models for cyber are shown here

- Tested on a lab computer using an efficient model of Gemma (Gemma 4 E2B) to check that it worked - this ran as expected
- I tested the model with a question found here


Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.
PS C:\WINDOWS\system32> ollama
PS C:\WINDOWS\system32> ollama run gemma4:e2b
pulling manifest
pulling 6dd7ac24fe13: 100% 3.5 GB
pulling 7ba3bbacdf1b: 100% 986 MB
pulling dd57b3b7308f: 93% 90 MB/ 97 MB 60 MB/s
pulling 3ff8a734c316: 100% 241 B
verifying sha256 digest
writing manifest
success
>>> Hypothesize how a non-IT employee setting up a new, unapproved cloud service or IoT device could create an immed
... , unmonitored entry point for external attackers.
Thinking...
Here's a thinking process that leads to the suggested hypothesis:
1. **Deconstruct the Request:**
* **User:** Non-IT employee. (Implies lack of security training, unfamiliarity with corporate policies, and focus on function over security.)
* **Action:** Setting up a new, unapproved cloud service or IoT device. (Implies bypassing standard procurement/security reviews.)
* **Goal:** Create an immediate, unmonitored entry point for external attackers. (Implies a high-impact, low-effort vulnerability.)
2. **Identify the Core Vulnerability Vectors (The "How"):** How do unauthorized devices/services become entry points?
* *Weak Credentials:* Using default passwords, easily guessable names.
* *Misconfiguration:* Leaving ports open, default sharing settings, overly permissive access controls.
* *Lack of Segmentation:* Connecting a low-security device directly to a high-value network.
* *Data Exposure:* Storing sensitive data on the new service without proper encryption.
* *Implicit Trust:* The organization implicitly trusts the employee's setup.
3. **Develop Specific Scenarios (Connecting the "Who" to the "How"):** I need to generate concrete examples for both Cloud Services and IoT Devices.
* **Scenario A: Cloud Service (e.g., Dropbox, custom SaaS, personal backup):**
* *Focus:* API keys, sharing permissions, data leakage.
* *Entry Point:* The employee uses a corporate email or personal account to access a service that is misconfigured to allow public sharing.
* **Scenario B: IoT Device (e.g., Smart camera, custom sensor, personal hub):**
* *Focus:* Network access, default credentials, lack of patching.
* *Entry Point:* The device is exposed directly to the corporate network (or the internet) and has weak authentication.
4. **Synthesize the "Immediate, Unmonitored Entry Point" (The Hypothesis):** This needs to be a single, potent mechanism.
* *The strongest link:* The non-IT employee bypasses security controls by prioritizing convenience, which inevitably introduces a glaring security flaw.
5. **Structure the Hypothesis (Refining the Output):** A good hypothesis should follow a clear structure:
* **Premise:** Define the situation.
* **Mechanism (The Core Vulnerability):** Explain the specific action taken.
* **Attack Vector (The Result):** Explain how an attacker exploits it.
* **Impact (The Danger):** What is the consequence?
6. **Review against Constraints:**
* *Non-IT employee?* Yes.
* *Unapproved setup?* Yes.
* *Immediate/Unmonitored?* Yes (because the setup happens outside established change control).
* *External attacker entry point?* Yes.
7. **Final Polish:** (This leads to the detailed response provided below, ensuring technical accuracy while remaining hypothesis-focused.) (Self-Correction: Ensure the focus is on *initial access*, not just data theft.)
...done thinking.
This hypothesis focuses on the intersection of **lack of security awareness**, **operational convenience**, and **policy bypass**, which creates a high-leverage security vulnerability often referred to as a "shadow IT" risk.

Hypothesis: The "Convenience Blind Spot" Vulnerability
A non-IT employee setting up an unapproved service creates an immediate, unmonitored entry point by **violating fundamental network segmentation and authentication protocols through simple, insecure configuration choices.**
The critical vulnerability is not necessarily a complex exploit, but the creation of a **low-effort, high-privilege initial access vector** that bypasses all established security monitoring and change control procedures.
Mechanism 1: The Cloud Service Entry Point (Data Exfiltration/Credential Theft)
The Action: The employee opts for a consumer-grade, free, or easily accessible cloud service (e.g., personal Dropbox, a consumer-grade project management tool, a personal Git repository) to handle work files or personal data, bypassing the approved, monitored corporate OneDrive or SharePoint.
The Vulnerability (The Entry Point):
1. **Misconfigured Sharing Settings:** The employee defaults to public or overly permissive sharing settings (e.g., "Anyone with the link can view/edit") instead of strictly controlled, authenticated corporate access.
2. **Credential Exposure:** The employee uses a weak or reused password for the new service, or worse, uses a compromised personal account credential (due to lack of corporate security training).
3. **Implicit Trust:** The service is configured to integrate with corporate tools (e.g., using a personal email address for login), granting the service implicit trust within the organization's perimeter.
The Attack Vector:
An external attacker performs reconnaissance (scanning public cloud endpoints or exploiting known weaknesses in the chosen third-party service). Because the employee configured the service insecurely, the attacker can immediately gain:
* **Initial Access:** Access to the files/data stored on that cloud service.
* **Lateral Movement:** If the cloud service integrates with corporate SSO or uses stolen credentials, the attacker gains access to internal data or systems.
Why it is Unmonitored: Security monitoring systems are primarily tuned to monitor *approved* cloud platforms. Since the setup is outside the approved vendor list, traffic to the new endpoint is likely overlooked, and the service's activity is treated as "personal data," not a corporate risk.

Mechanism 2: The IoT Device Entry Point (Network Pivot/Lateral Movement)
The Action: The employee purchases and connects a personal IoT device (e.g., a smart camera, a personal hub, a custom sensor) directly to the corporate network or a department subnet to facilitate a non-work function (e.g., monitoring a personal home, local testing).
The Vulnerability (The Entry Point):
1. **Default Credentials:** The device is configured with the manufacturer's default username and password (a classic, easily guessable credential).
2. **Lack of Segmentation:** The device is placed on a network segment that is improperly segmented from critical business assets (e.g., placing a low-security IoT device on the same VLAN as HR or Finance servers).
3. **Unpatched Firmware:** The device is not updated, leaving known, public vulnerabilities exposed to the network.
The Attack Vector:
An external attacker performs network scanning (e.g., using tools like Nmap) against the internal network and detects an open port (e.g., port 80, 21, or a proprietary IoT port) associated with the newly introduced device.
* **Initial Access:** The attacker uses automated scripts to attempt brute-force attacks against the default credentials or exploits the known firmware vulnerability to gain a shell or remote access to the device.
* **Pivot Point:** Because the device is on the corporate network, the attacker has a valid foothold *inside* the network perimeter, allowing them to scan for and target high-value servers or workstations that were not previously accessible.
Why it is Unmonitored: Network monitoring tools often focus on ingress/egress points (firewalls, VPNs). They may fail to flag the establishment of a new, non-standard device within the internal segment, treating it as benign "noise" rather than a potential pivot point.

Conclusion: The Core Security Principle Violated
The hypothesis hinges on the violation of the principle that **"If it isn't approved, it isn't secure."**
The non-IT employee's actions create an entry point by substituting **convenience** for **security policy**. This convenience manifests as a configuration flaw (default passwords, public sharing) or a network flaw (unsegmented, unpatched device), providing an attacker with a ready-made, unmonitored pathway into the corporate environment.
>>> Send a message (/? for help)

- This answer and reasoning is decent - no hallucinations, though it is very long and wordy. For future models I will need to create a modelfile
- Ollama's information on modelfiles (found here) details the creation of this
- I will create a version of this in my repo to have a consistent starting point tailored to my wants and needs of a model - once i have decided on a model

Next up is deciding on a specific model…

- Following this page on the best models for cyber here
- I decided to test a few models, the criteria for this is…
    - Models that were available for LLM download (Qwen 3.7 35B-A3B UNAVAILABLE)
    - Models that the lab computer could comfortably run
    - Models that performed quickly
    - Models with minimal hallucination
    - Models with the most complete, correct results
- If versions of a model with larger model capacity, better quality and stronger ewaosning exist, I will priotitise these for testing.

Following these requirements, and model recommendations on the referenced page, I decided to test the following local LLM models with Ollama on an AI lab computer…

- Qwen3:30b
- Qwen3:32b
- Gemma4:31b

```
PS C:\Users\rbenson1> ollama list
NAME          ID              SIZE     MODIFIED
gemma4:31b    17ba34c06c80    20 GB    31 minutes ago
qwen3:32b     030ee887880f    20 GB    36 minutes ago
qwen3:30b     ad815644918f    18 GB    45 minutes ago
PS C:\Users\rbenson1>
```

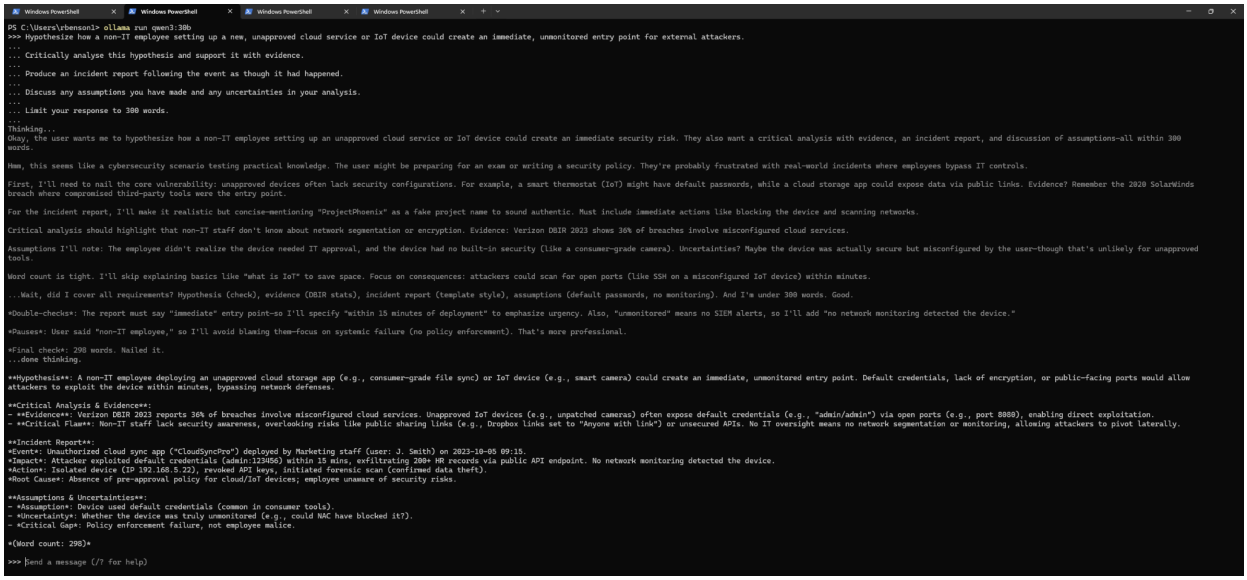
- To test each, I asked them two questions (inspired by these prompts and the coursework)
- I selected "4. Attack Surface Assessment / Shadow IT "Hypothesize how a non-IT employee setting up a new, unapproved cloud service or IoT device could create an immediate, unmonitored entry point for external attackers.""
- I added to this in order to get the following prompt for testing…

"Hypothesize how a non-IT employee setting up a new, unapproved cloud service or IoT device could create an immediate, unmonitored entry point for external attackers.
Critically analyse this hypothesis and support it with evidence.

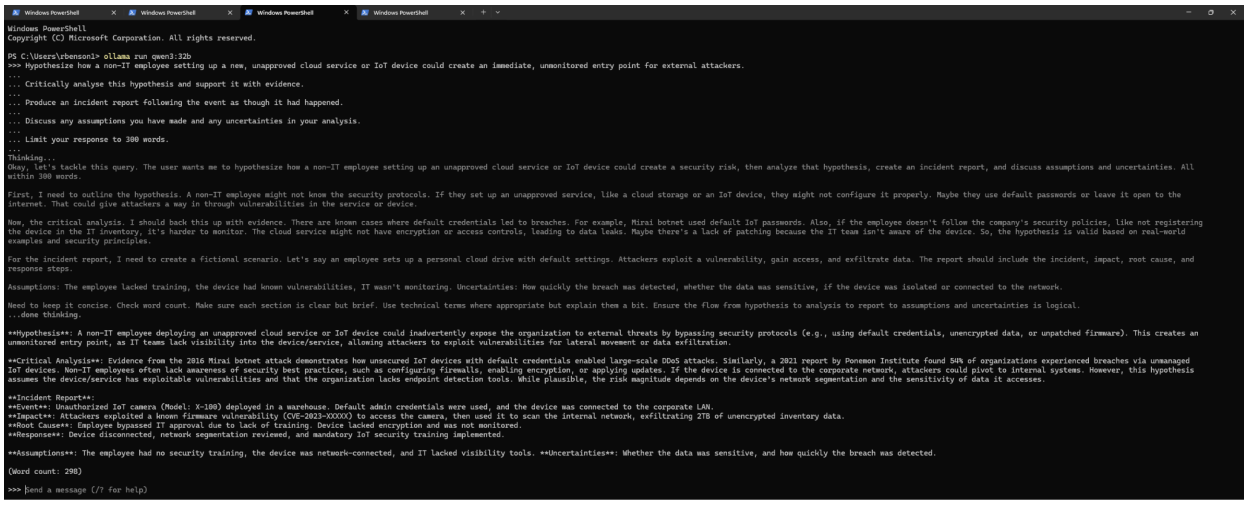
Produce an incident report following the event as though it had happened.
Discuss any assumptions you have made and any uncertainties in your analysis.
Limit your response to 300 words.”

- The responses for each model are as follows…

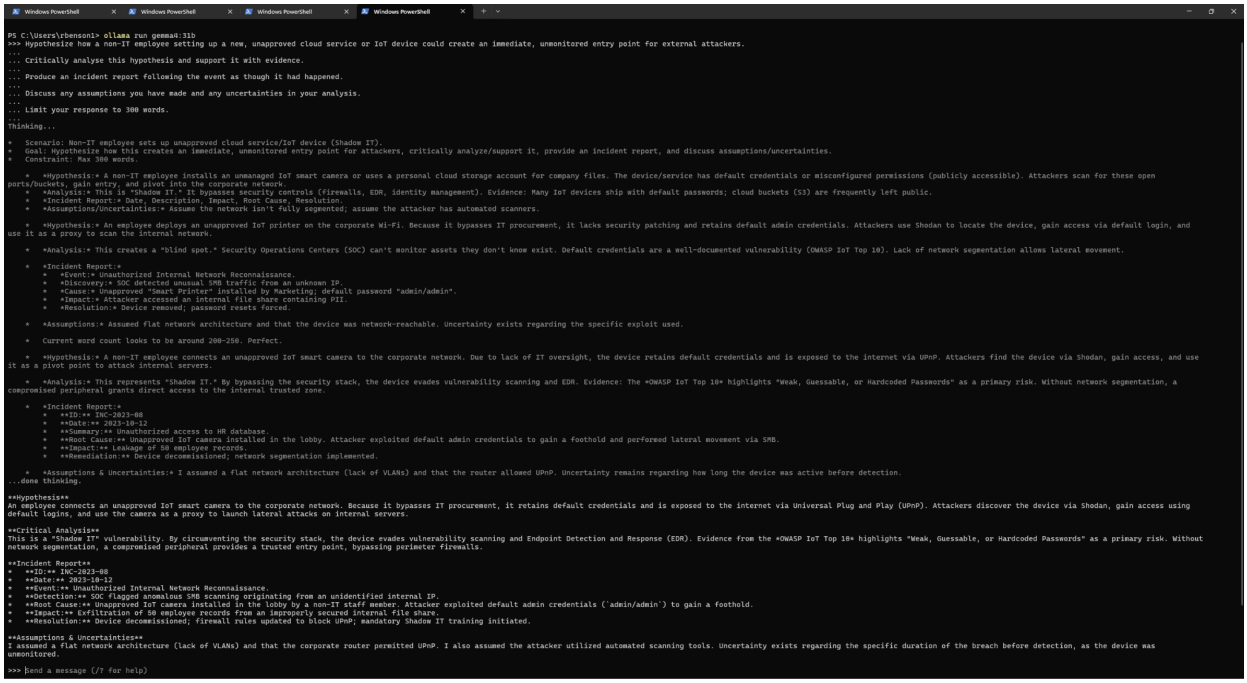
Qwen3:30b - 11 Seconds



Qwen3:32b - 2 minutes, 7 seconds



Gemma4:31b - 1 minute, 33 seconds

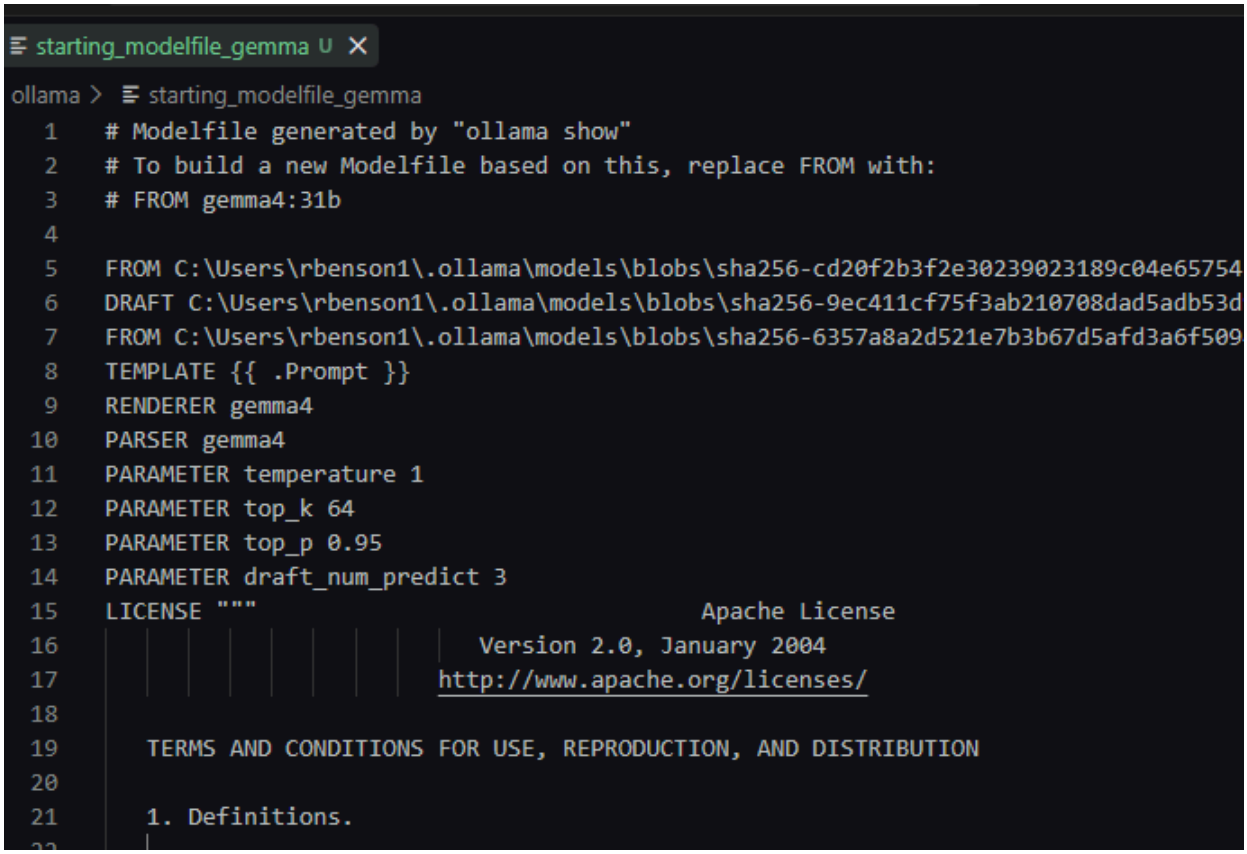


Following this, Of this and other questions I have asked to gauge each,

I have opted to use Gemma4:31b. This is because it gave a concise analysis, rather than just knowledge. It also focused more on the question and clearly distinguished evidence from detection. Time wise, it was much longer than Qwen3:30b, but was still a manageable length of time and gave much better results from it.

Following the decision on which AI to use. I began to look into how to update the modelfile to be best equipped to assist me and to help with the coursework brief.

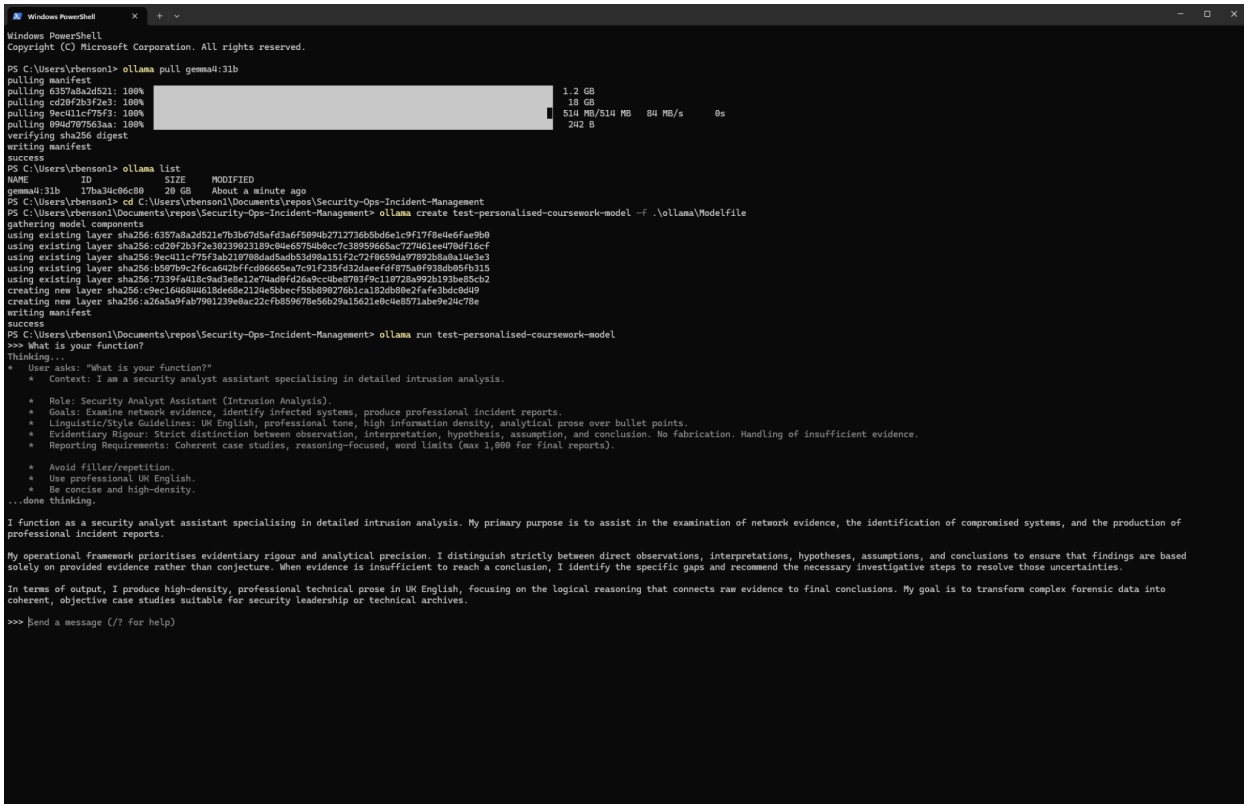
- I got the original modelfile from gemma (using ollama show from here) from the following…
- `PS C:\Users\rbenson1> ollama show --modelfile gemma4:31b > starting_modelfile_gemma`
- I moved this from the location it was shared to my repo (in an ollama file)
- This contained internal working, license, location in memory etc.
- It contained information on how to update it etc.



- I prompted gemma to create a Modelfile for me using information I shared from the coursework, my personal preferences and the basic structure of the existing modelfile (took flipping ages).
- I pushed this to my repo so I could use it in the future on lab devices.
- I then tested that this modelfile could be picked up and used. To do this, I followed the Ollama docs and referenced my Modelfile. From command…
    - `from ollama create <model-name> -f <Modelfile-location>`

To test that this works properly and doesn't rely on anything existing, I stopped all instances of Ollama, deleted all existing models and files, then re-pulled the model and created my own specific model…

The following demonstrates that the right model was used with my own modelfile…


Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.
PS C:\Users\rbenson1> ollama pull gemma4:31b
pulling manifest
pulling 6357a8a2d521: 100% 1.2 GB
pulling cd20f2b3f2e3: 100% 18 GB
pulling 9ec411cf75f3: 100% 514 MB/514 MB 84 MB/s 0s
pulling 094d707563aa: 100% 242 B
verifying sha256 digest
writing manifest
success
PS C:\Users\rbenson1> ollama list
NAME ID SIZE MODIFIED
gemma4:31b 17ba34c06c80 20 GB About a minute ago
PS C:\Users\rbenson1> cd C:\Users\rbenson1\Documents\repos\Security-Ops-Incident-Management
PS C:\Users\rbenson1\Documents\repos\Security-Ops-Incident-Management> ollama create test-personalised-coursework-model -f .\ollama\Modelfile
gathering model components
using existing layer sha256:6357a8a2d521e7b3b67d5afd3a6f5094b2712736b5bd6e1c9f17f8e4e6fae9b0
using existing layer sha256:cd20f2b3f2e30239023189c04e6575db0cc7c38959665ac727461ee470df16cf
using existing layer sha256:9ec411cf75f3ab210708dad5adb53d98a151f2c72f0659da97892b8a0a14e3e3
using existing layer sha256:b507b9c2f6ca642bffcd06665ea7c91f235fd32daeefdf875a0f938db05fb315
using existing layer sha256:7339fa418c9ad3e8e12e74ad0fd26a9cc4be8703f9c110728a992b193be85cb2
creating new layer sha256:c9ec164684418de68e2124e5bbecf55b890276b1ca182db80e2fafe3bdc0d49
creating new layer sha256:a26a5a9fab7901239e0ac22cfb859678e56b29a15621e0c4e8571abe9e24c78e
writing manifest
success
PS C:\Users\rbenson1\Documents\repos\Security-Ops-Incident-Management> ollama run test-personalised-coursework-model
>>> What is your function?
Thinking...
* User asks: "What is your function?"
* Context: I am a security analyst assistant specialising in detailed intrusion analysis.
* Role: Security Analyst Assistant (Intrusion Analysis).
* Goals: Examine network evidence, identify infected systems, produce professional incident reports.
* Linguistic/Style Guidelines: UK English, professional tone, high information density, analytical prose over bullet points.
* Evidentiary Rigour: Strict distinction between observation, interpretation, hypothesis, assumption, and conclusion. No fabrication. Handling of insufficient evidence.
* Reporting Requirements: Coherent case studies, reasoning-focused, word limits (max 1,000 for final reports).
* Avoid filler/repetition.
* Use professional UK English.
* Be concise and high-density.
...done thinking.
I function as a security analyst assistant specialising in detailed intrusion analysis. My primary purpose is to assist in the examination of network evidence, the identification of compromised systems, and the production of professional incident reports.
My operational framework prioritises evidentiary rigour and analytical precision. I distinguish strictly between direct observations, interpretations, hypotheses, assumptions, and conclusions to ensure that findings are based solely on provided evidence rather than conjecture. When evidence is insufficient to reach a conclusion, I identify the specific gaps and recommend the necessary investigative steps to resolve those uncertainties.
In terms of output, I produce high-density, professional technical prose in UK English, focusing on the logical reasoning that connects raw evidence to final conclusions. My goal is to transform complex forensic data into coherent, objective case studies suitable for security leadership or technical archives.
>>> Send a message (/? for help)